ENTERPRISE RANSOMWARE ASSESSMENT

Drafted a Corporate Risk Register Mapped to the NIST Cybersecurity Framework (CSF)

PROJECT TOPIC

10 — Enterprise Ransomware Assessment

SUBMITTED BY

Ritika Sonali Suryawanshi

COLLEGE

Sandip University, Nashik

SUBJECT AREA

Cybersecurity Bootcamp

PROJECT REPORT

This academic report uses a hypothetical medium-sized enterprise. Risk scores and existing-control assumptions are illustrative, not findings from a real organisation.

October 2026

Project Scope and Important Note

This project corresponds specifically to **Project Topic No. 10** from the provided Cybersecurity Bootcamp project list: “Enterprise Ransomware Assessment: Drafted a corporate risk register mapped to the NIST CSF framework.” It develops a ransomware-focused corporate risk register and maps recommendations to the NIST Cybersecurity Framework (CSF) 2.0.

The enterprise is hypothetical. No real organisation was scanned, tested, or assessed, and this report does not claim that Sandip University has the risks described. The NIST CSF is an outcome-based framework; the mapping below is an illustrative guide and should be tailored to the organisation’s business context and verified controls.

Contents

Section	Coverage
	Purpose and priority actions
2. Objectives and Scope	Boundaries, assumptions, and exclusions
	Likelihood, impact, and residual scoring
4. Enterprise Context	Critical assets and ransomware scenario
	Ten risks, treatment actions, owners, and NIST CSF mapping
6. 90-Day Treatment Roadmap	Prioritised implementation plan
	Prepare, detect, contain, eradicate, recover, and improve
8. Governance and Metrics	Responsibilities, KPIs, and review triggers
	Summary and short declaration
References and Glossary	Authoritative framework and ransomware resources

1. Executive Summary

Ransomware is an enterprise risk because it can disrupt operations, deny access to systems, expose sensitive information, and create recovery, legal, financial, and reputational consequences. Effective management combines governance, prevention, detection, response, and tested recovery rather than relying on a single security tool.

This assessment considers a hypothetical medium-sized enterprise with employee endpoints, identity services, email, shared storage, cloud services, business applications, supplier connections, and backup infrastructure. Ten ransomware-related risks are assessed using a 5 × 5 qualitative model and mapped to relevant NIST CSF 2.0 Functions and example Categories.

Priority recommendations

• Protect privileged and remote access with multi-factor authentication (MFA), least privilege, and account reviews.
• Maintain a reliable inventory and prioritise patching of critical and internet-facing systems.
• Improve endpoint monitoring and centralise important security logs.
• Protect backup copies from unauthorised alteration and test restoration regularly.
• Approve a ransomware response playbook and practise it through a tabletop exercise.

2. Objectives and Scope

Objectives: identify major ransomware risks; estimate likelihood and business impact; document treatment options, accountable owners, and evidence; map controls to NIST CSF 2.0; and propose a practical 90-day roadmap.

Scope includes endpoints, servers, identity and access, email, remote access, cloud services, shared data, backups, network segmentation, logging, suppliers, incident response, and business continuity. Excluded are penetration testing, live malware execution, vulnerability scanning, and assessment of any real organisation.

Assumptions: approximately 500 employees, a hybrid work environment, a small IT/security team, and partially implemented controls whose effectiveness has not been independently verified. All scores, owners, and dates are illustrative.

3. Risk Assessment Methodology

Inherent risk = Likelihood × Impact, before considering controls. Scores range from 1 to 25. Residual scores are planning estimates after assumed or recommended controls; they are not measured probabilities.

Score	Likelihood	Impact
	Rare	Insignificant disruption
2	Unlikely	Minor team-level disruption
	Possible	Multiple teams or moderate service impact
4	Likely	Major service disruption or sensitive data exposure
	Almost certain	Severe or prolonged enterprise-wide impact

Risk bands: 1–4 Low; 5–9 Moderate; 10–16 High; 17–25 Critical. High and Critical risks should receive priority treatment and management oversight. Risk acceptance must be approved by an authorised business risk owner.

NIST CSF 2.0 has six Functions: Govern (GV), Identify (ID), Protect (PR), Detect (DE), Respond (RS), and Recover (RC). The register uses relevant example Categories, including GV.RR, GV.PO, GV.SC, ID.AM, ID.RA, ID.BE, PR.AA, PR.AT, PR.PS, PR.DS, PR.IR, DE.CM, DE.AE, RS.MA, RS.CO, RS.AN, RC.RP, RC.CO, and GV.OV. Refer to the official CSF 2.0 resources for exact outcomes and tailoring.

4. Enterprise Context and Ransomware Scenario

Critical assets include identity services, employee endpoints, email and collaboration, file storage, business applications, backup platforms, cloud workloads, remote access, and third-party connections. Their protection supports confidentiality, integrity, and availability.

Illustrative attack path: a phishing message or vulnerable exposed service may provide initial access. An attacker may obtain credentials, increase privileges, move between systems, identify valuable data, interfere with security controls or backups, exfiltrate information, and deploy ransomware. Not every incident follows the same sequence.

Business consequences can include unavailable systems, lost productivity, data exposure, recovery costs, contractual or regulatory obligations, and reputational harm. Ransom payment does not guarantee data recovery or deletion of stolen information.

5. Corporate Ransomware Risk Register

The current-control column represents assumptions for this hypothetical scenario and is not verified evidence. Target actions should be agreed by the organisation and tracked to completion.

ID	Risk scenario	L	I	Inherent score	Owner	Residual
R1	Phishing or malicious email compromises an endpoint	4	5	20 Critical	Security Lead / IT Operations	10 High
R2	Privileged or remote-access account compromise	4	5	20 Critical	Identity Administrator	8 Moderate
R3	Exploitation of unpatched or vulnerable systems	4	4	16 High	Infrastructure Manager	8 Moderate
R4	Ransomware spreads across network segments	3	5	15 High	Network Manager	8 Moderate
R5	Backup data or administration is compromised	3	5	15 High	Backup / Recovery Lead	6 Moderate
R6	Sensitive data is exfiltrated before or during encryption	3	5	15 High	Data Owner / Privacy Lead	9 Moderate
R7	Security alerts are missed or investigated too slowly	4	4	16 High	SOC / Security Lead	8 Moderate
R8	Third-party access introduces ransomware risk	3	4	12 High	Vendor Risk Manager / IT	6 Moderate
R9	Incident response roles and communication are unclear	3	4	12 High	CISO / Business Continuity Lead	6 Moderate
R10	Recovery objectives are unrealistic or untested	3	5	15 High	Business Continuity Lead / Service Owners	8 Moderate

Risk detail cards

Risk / ID	**R1 — Phishing or malicious email compromises an endpoint**
Cause / vulnerability	User opens a malicious link/attachment or approves a fraudulent sign-in.
Business impact	Initial access, credential theft, malware execution, and disruption.
Inherent risk	Likelihood 4 × impact 5 = 20 Critical
Current-control assumption	Email filtering and basic awareness assumed; unverified.
Treatment action	Tune email protection; restrict risky attachment types; enable strong MFA; train users to report suspicious messages.
Owner / residual risk	Security Lead / IT Operations / 10 High (estimate; verify effectiveness)
NIST CSF mapping	PR.AT; PR.PS; DE.CM; RS.MA

Risk / ID	**R2 — Privileged or remote-access account compromise**
Cause / vulnerability	Weak authentication, reused passwords, excess privileges, or exposed remote access.
Business impact	Broad access, control disabling, and enterprise-wide impact.
Inherent risk	Likelihood 4 × impact 5 = 20 Critical
Current-control assumption	Some MFA and password rules assumed; coverage unknown.
Treatment action	Enforce MFA for remote/admin access; separate admin accounts; remove stale accounts; apply least privilege; alert on unusual sign-ins.

Owner / residual risk	Identity Administrator / 8 Moderate (estimate; verify effectiveness)
NIST CSF mapping	PR.AA; DE.CM; GV.RR

Risk / ID	**R3 — Exploitation of unpatched or vulnerable systems**
Cause / vulnerability	Delayed patching, unsupported software, or incomplete asset inventory.
Business impact	Initial access, privilege escalation, or service disruption.
Inherent risk	Likelihood 4 × impact 4 = 16 High
Current-control assumption	Routine patching assumed; coverage unknown.
Treatment action	Inventory assets; prioritise internet-facing and actively exploited vulnerabilities; define patch SLAs; track exceptions.
Owner / residual risk	Infrastructure Manager / 8 Moderate (estimate; verify effectiveness)
NIST CSF mapping	ID.AM; ID.RA; PR.PS; GV.PO

Risk / ID	**R4 — Ransomware spreads across network segments**
Cause / vulnerability	Flat network, shared admin credentials, or broad file-share permissions.
Business impact	Multiple systems may become encrypted or unavailable.
Inherent risk	Likelihood 3 × impact 5 = 15 High
Current-control assumption	Network controls assumed; segmentation untested.
Treatment action	Segment critical servers and backups; restrict admin pathways; use unique admin credentials; test containment.
Owner / residual risk	Network Manager / 8 Moderate (estimate; verify effectiveness)
NIST CSF mapping	PR.IR; PR.AA; DE.CM; RS.MA

Risk / ID	**R5 — Backup data or administration is compromised**
Cause / vulnerability	Backups writable from production accounts or restoration is not tested.
Business impact	Recovery may be delayed or impossible.
Inherent risk	Likelihood 3 × impact 5 = 15 High
Current-control assumption	Scheduled backups assumed; immutability and restore success unknown.
Treatment action	Maintain immutable/offline copies; separate backup identities; restrict deletion; monitor changes; test restoration.
Owner / residual risk	Backup / Recovery Lead / 6 Moderate (estimate; verify effectiveness)
NIST CSF mapping	PR.DS; PR.AA; RC.RP; RC.CO

Risk / ID	**R6 — Sensitive data is exfiltrated before or during encryption**
Cause / vulnerability	Broad data access, weak egress monitoring, or unclassified sensitive data.
Business impact	Privacy, legal, contractual, competitive, and reputational harm.
Inherent risk	Likelihood 3 × impact 5 = 15 High
Current-control assumption	Permissions and basic logs assumed; data classification unknown.
Treatment action	Classify data; apply least privilege; review sharing; monitor bulk access and outbound transfers; prepare privacy escalation.
Owner / residual risk	Data Owner / Privacy Lead / 9 Moderate (estimate; verify effectiveness)
NIST CSF mapping	ID.AM; PR.DS; DE.CM; RS.CO

Risk / ID	**R7 — Security alerts are missed or investigated too slowly**
Cause / vulnerability	Incomplete logs, alert overload, limited staffing, or unclear escalation.
Business impact	Longer attacker dwell time and increased disruption.
Inherent risk	Likelihood 4 × impact 4 = 16 High
Current-control assumption	Antivirus and system logs assumed; monitoring coverage unknown.
Treatment action	Centralise critical logs; define high-priority detections and triage SLAs; test alert routing and after-hours escalation.
Owner / residual risk	SOC / Security Lead / 8 Moderate (estimate; verify effectiveness)
NIST CSF mapping	DE.CM; DE.AE; RS.MA

Risk / ID	**R8 — Third-party access introduces ransomware risk**
Cause / vulnerability	Supplier compromise, excessive access, or weak supplier practices.
Business impact	Attack may enter through trusted connections.
Inherent risk	Likelihood 3 × impact 4 = 12 High

Current-control assumption	Supplier approvals assumed; assurance unknown.
Treatment action	Inventory critical suppliers; use named, time-bound accounts and MFA; review incident clauses; monitor and revoke access.
Owner / residual risk	Vendor Risk Manager / IT / 6 Moderate (estimate; verify effectiveness)
NIST CSF mapping	GV.SC; PR.AA; ID.RA; RS.CO

Risk / ID	**R9 — Incident response roles and communication are unclear**
Cause / vulnerability	No current playbook, stale contacts, or uncertain decision authority.
Business impact	Delayed containment and inconsistent decisions or messaging.
Inherent risk	Likelihood 3 × impact 4 = 12 High
Current-control assumption	General IT support assumed; exercise evidence unavailable.
Treatment action	Approve ransomware playbook; identify incident commander; maintain legal/privacy/leadership contacts; run a tabletop.
Owner / residual risk	CISO / Business Continuity Lead / 6 Moderate (estimate; verify effectiveness)
NIST CSF mapping	GV.RR; RS.MA; RS.CO; RS.AN

Risk / ID	**R10 — Recovery objectives are unrealistic or untested**
Cause / vulnerability	RTO/RPO undefined or no recovery exercise evidence.
Business impact	Extended outage, unacceptable data loss, and missed commitments.
Inherent risk	Likelihood 3 × impact 5 = 15 High
Current-control assumption	Backups/continuity documents assumed; test evidence unavailable.
Treatment action	Approve service RTO/RPO; map dependencies; test restores and recovery exercises; document lessons.
Owner / residual risk	Business Continuity Lead / Service Owners / 8 Moderate (estimate; verify effectiveness)
NIST CSF mapping	RC.RP; RC.CO; ID.BE; GV.OV

6. Risk Treatment Plan: 90-Day Roadmap

Period	Actions	Evidence / deliverables
	Confirm critical assets and service owners; verify MFA for privileged/remote access; review admin accounts; check critical patch exposure and backup status; approve incident contacts.	Asset inventory; MFA report; privileged account review; patch/backup status; contact tree.
Days 31–60: Strengthen	Close critical patch gaps; validate endpoint protection; centralise identity/endpoint/email/server/backup logs; restrict backup administration; review supplier access; agree RTO/RPO.	Patch dashboard; endpoint coverage; logging register; backup access review; supplier review; approved recovery objectives.
	Test restoration of representative services; conduct ransomware tabletop; test alert escalation and containment decisions; update risk register and document accepted risks.	Restore-test report; tabletop report; tracked lessons; updated register; authorised risk acceptance.

Treatment options

Mitigate by improving controls; avoid by stopping an unjustifiable risky activity; transfer/share selected financial impacts through suitable contractual or insurance arrangements; or accept only when an authorised risk owner documents the rationale, safeguards, and review date.

7. Incident Response and Recovery Plan

Prepare: maintain a playbook, response roles, contact list, out-of-band communication, critical-service list, and approved recovery objectives.

Detect and assess: validate alerts using endpoint, identity, email, network, server, and backup telemetry. Record discovery time, affected systems/accounts, potential data sensitivity, and business impact; assign severity and an incident commander.

Contain: use authorised procedures to isolate affected systems or segments and restrict compromised accounts/tokens. Protect backup administration. Preserve relevant evidence and follow approved procedures before wiping, rebuilding, or powering off systems.

Eradicate and recover: determine the scope and initial access; close exploited weaknesses; restore from known-good backups or clean builds; prioritise services by business dependencies; validate system integrity and monitoring before returning to service.

Communicate and improve: coordinate internal and any external notifications through authorised legal, privacy, leadership, and communications roles. Record the timeline, decisions, recovery evidence, and lessons learned. Ransom payment does not guarantee recovery or confidentiality.

8. Governance and Metrics

Metric	Example indicator	Review
	All privileged and remote access protected; exceptions documented and time-bound.	Monthly
Critical patch compliance	Critical internet-facing issues fixed within approved SLA or formally excepted.	Weekly/monthly
	Supported enterprise endpoints report to approved management console.	Weekly
Logging coverage	Critical identity, endpoint, email, server, and backup logs onboarded.	Monthly
	Representative critical workloads restored and validated successfully.	Quarterly / risk-based
Exercise readiness	At least one ransomware tabletop annually and after major changes.	Annual
	Overdue high/critical actions escalated; accepted risks have approver and review date.	Monthly

Governance roles

Executive sponsor: provides direction and resources. Risk owner: accountable for treatment and acceptance. Control owner: implements controls and supplies evidence. Security team: coordinates monitoring and incident response. Business/service owner: sets service criticality and recovery priorities.

Review the register quarterly and after a material technology change, supplier integration, significant vulnerability, security incident, failed restore test, audit finding, or change in business priorities.

9. Conclusion

This project demonstrates a structured approach to assessing enterprise ransomware risk and mapping risk treatments to NIST CSF 2.0. The ten illustrative risks cover phishing, identity compromise, vulnerable systems, network spread, backup compromise, data exfiltration, detection gaps, third-party access, response readiness, and recovery capability. Sustainable risk reduction depends on clear ownership, layered controls, verified evidence, tested recovery, and regular management review.

Declaration

I, **Ritika Sonali Suryawanshi**, declare that this project has been prepared for academic purposes. The enterprise scenario and risk ratings are illustrative, and the references used are listed below.

Glossary

Term	Meaning
	Malicious activity that denies access to systems/data, commonly through encryption, and may also involve data theft or extortion.
Risk register	A structured record of risks, ratings, owners, controls, treatment actions, and status.
	Risk estimated before considering controls.
Residual risk	Risk remaining after controls and treatment.
	Multi-factor authentication; uses more than one factor to verify identity.
EDR	Endpoint detection and response; technology/processes for identifying and investigating endpoint threats.
	Recovery Time Objective: target time to restore a service after disruption.
RPO	Recovery Point Objective: acceptable data loss measured in time.
	NIST Cybersecurity Framework, used to organise and communicate cybersecurity risk management.

References

1. National Institute of Standards and Technology (NIST). (2024). Cybersecurity Framework (CSF) 2.0. https://www.nist.gov/cyberframework

2. NIST. (2024). The NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29. https://doi.org/10.6028/NIST.CSWP.29

3. Cybersecurity and Infrastructure Security Agency (CISA). StopRansomware resources and guidance. https://www.cisa.gov/stopransomware

4. NIST Computer Security Resource Center. Cybersecurity publications and glossary. https://csrc.nist.gov/publications

5. NIST. Computer Security Incident Handling Guide, SP 800-61 Rev. 2 (background reference; check for newer guidance). https://doi.org/10.6028/NIST.SP.800-61r2

— End of Project —